

MODULE 3 Activity Worksheet

BeEF Browser Hooking · CIA Triad Mapping · Security Terminology

Name:

Date: 19 March 2026
BBC Academy / JBI Training

How to use this worksheet:

Complete each section during the BeEF practical activity in Module 3 (12:00–13:00, Day 1). Your instructor will tell you when to move to each section. Write directly in the spaces provided — this worksheet is yours to keep.

Sections on this sheet: A — BeEF command log · B — CIA property mapping · C — Security terminology · D — Reflection

Activity 1 — Firefox DevTools (10 min)

DELEGATE INSTRUCTIONS:

Open Firefox. Navigate to <http://localhost:3001> (Juice Shop).
Press F12 to open Developer Tools.
Click the Network tab. Reload the page with Ctrl+Shift+R (hard reload).
Look at the list of requests that appeared. Click the first request (the main HTML document).
In the right panel, click Headers. Find and note down: the Server header, the Content-Type, and any security headers like X-Content-Type-Options.
Now click the Response tab. This is the raw HTML your browser received.
Switch to the Sources tab. Find the main JavaScript file. Look for any strings starting with `/api/` — these are internal API endpoints.

Activity 2 — ZAP Proxy HTTP Interception (10 min)

DELEGATE INSTRUCTIONS:

In Firefox, browse to <http://localhost:3001>. You will see ZAP capturing the traffic in the History tab.
Log in to Juice Shop with: email = `admin@juice-sh.op` / password = `admin123`
In ZAP, find the POST request to `/rest/user/login` in the History panel.
Right-click it → Open in Requester. Look at the request body. What credentials did you send?
Look at the response body. Find the token field. This is a JWT (JSON Web Token) — note its format: three base64 parts separated by dots.
Paste the token into <https://jwt.io> (open in a new tab) and decode it. What information is stored in the token payload?

Activity 3 — BeEF Browser Hook (30 min)

DELEGATE INSTRUCTIONS:

STEP 1: Start BeEF. Click the BeEF desktop shortcut or run: `cd ~/beef && ./beef` in a terminal.
Wait for the startup message. You should see: `[*] BeEF is loading. Please wait...`
BeEF UI will open in Firefox at: <http://localhost:3000/ui/panel>
Log in to BeEF with: Username = `beef` / Password = `beebeecee` (check `~/beef/config.yaml` if this fails)

STEP 2: Open a SECOND Firefox tab (Ctrl+T).
Navigate to: <http://localhost:3000/demos/basic/> — this is the BeEF hook page.

STEP 3: Back in the BeEF UI tab, look at the left panel — "Hooked Browsers".

You should see your own browser appear, listed by IP address (127.0.0.1).

STEP 4: Click on the hooked browser entry.

In the Commands tab, explore these modules:

- Browser → Get Cookies
- Browser → Get Browser Version
- Network → Fingerprint Network
- User Interface → Alert Dialog (try this — it pops an alert in your hooked tab)

STEP 5: For each command you run, note: which CIA property does it attack? Record in your handout.



Section A — BeEF Command Log

As you run each BeEF command, record it here. You need at least 5 entries.

For each BeEF command you execute, fill in one row. Commands are found in the Commands tab of the BeEF UI (<http://localhost:3000/ui/panel>).

#	BeEF Command Name (e.g. Get Cookies)	What data / capability did it return?	CIA property attacked (C / I / A / C+I / ...)	Visible in server logs? What would the log show?
1	EXAMPLE: Get Cookies	Returns all cookies set on the hooked page, including session tokens	C (Confidentiality — data theft)	NO — BeEF runs in the browser. Zero HTTP requests reach the web server.
2				
3				
4				
5				
6				
7				
8				
Row 1 is a worked example. Try at least: Get Cookies · Get Browser Version · Fingerprint Network · Alert Dialog · Get History · Network Discover Hosts				



Section B — CIA Triad: What Each Property Means

Complete the definitions, then use them to score your command log above

C

Confidentiality

I

Integrity

A

Availability

In my own words,
Confidentiality means:

A BeEF command from my log
that attacks C:

In my own words, Integrity
means:

A BeEF command from my log
that attacks I:

In my own words, Availability
means:

A BeEF command from my log
that attacks A:

 Key insight to record:

In your command log above, check the "Visible in server logs?" column. How many of your entries say NO?

Complete this sentence: "BeEF demonstrates that server-side logging is _____ as a complete defence because _____."

Section C — Security Terminology: Four Words You Must Own

Fill in your own definitions, then complete the BeEF attack chain using all four terms

These four terms are used imprecisely in industry but have precise meanings. Fill in the definition column in your own words, then complete the BeEF example column.

Term	My definition in one sentence	Applied to the BeEF exercise — complete the sentence	Applies to... (tick all that fit)
THREAT		"A threat exists because an attacker could _____."	☐ The existence of BeEF as a tool ☐ An attacker who sends a phishing link ☐ The browser trust model (JS execution) ☐ Stolen cookies in your command log
VULNERABILITY		"The vulnerability here is _____ in the browser's design."	☐ The existence of BeEF as a tool ☐ An attacker who sends a phishing link ☐ The browser trust model (JS execution) ☐ Stolen cookies in your command log
EXPLOIT		"The exploit I performed was: _____."	☐ The existence of BeEF as a tool ☐ An attacker who sends a phishing link ☐ The browser trust model (JS execution) ☐ Stolen cookies in your command log
INCIDENT		"This becomes an incident when _____."	☐ The existence of BeEF as a tool ☐ An attacker who sends a phishing link ☐ The browser trust model (JS execution) ☐ Stolen cookies in your command log

✓ **Answer key for the tick boxes (check after discussion):** Threat → lines 1 and 3. Vulnerability → line 3. Exploit → lines 2 and 4. Incident → line 4 (when it happens to a real user/system).

Section D — Reflection Questions

Answer in your own words. There are no correct answers — only unexplored ones.

Take 5 minutes to write brief answers before the group discussion. One or two sentences per question is enough.

Q1 BeEF ran entirely inside the browser. The web server received no unusual HTTP requests. What does this tell you about where security controls must be placed?

Q2 A colleague says: "We're safe because we use HTTPS." Based on what you just did with BeEF, what would you say to them?

Q3 Looking at the "Visible in server logs?" column of your command log: what category of security control does logging fall under — Preventive, Detective, or Corrective? What does your evidence suggest about its completeness as a sole control against browser-based attacks?



Overnight question for tonight (answer on Day 2, Module 7):

BeEF can execute JavaScript in any browser that visits the hook page. ShopCo's ping tool (Flaw 8) can execute OS commands on the server. **If you could chain these two capabilities together — starting from a phishing email sent to a BBC employee — what would each step of the complete attack look like?**

There is no single right answer. Think about what the attacker controls at each stage, and what they need to acquire to move to the next step. Write your chain here:
